

**ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG**

**Nguyễn Tài Phú - 23521185
Trần Minh Nhật - 23521099
Châu Hoàng Phúc - 23521191**

**ĐỒ ÁN MÔN HỌC
Lập trình kịch bản tự động hóa cho quản trị và bảo mật mạng**

Triển khai CIS Benchmark trên hệ thống Linux

Linux CIS Benchmark Implementation

**GIẢNG VIÊN HƯỚNG DẪN
Thạc sĩ Trần Thị Dung**

TP. HỒ CHÍ MINH, NĂM 2026

Mục lục

Mục lục	i
1 Tổng quan hệ thống	1
1.1 Tổng quan CIS	1
1.2 Tổng quan Linux	1
1.2.1 Manual Hardening	2
1.2.2 Automated Hardening	2
2 Phương pháp triển khai	13
2.1 Quy trình tổng thể	13
2.2 Phương pháp tiếp cận	13
2.2.1 Manual Configuration	13
2.2.2 Automation Configuration	14
2.3 Thiết kế hệ thống Ansible	16
2.3.1 Inventory	16
2.3.2 Playbooks	17
2.3.3 Roles	17
3 Triển khai	19
3.1 Mô hình triển khai	19
3.1.1 Quy trình Automated Security Hardening	20
3.2 Manual	21
3.2.1 Initial Setup	21
3.2.2 Services Configuration	23
3.2.3 Network Security	24
3.2.4 Firewall Configuration	25
3.2.5 Access Control	26
3.2.6 Logging & Auditing	28
3.2.7 System Maintenance	30
3.3 Automation	31
3.3.1 Initial Setup Automation	31
3.3.2 Services Automation	34

3.3.3	Network Security Automation	36
3.3.4	Firewall Automation	37
3.3.5	Access Control Automation	39
3.3.6	Logging & Auditing Automation	42
3.3.7	System Maintenance Automation	45
4	Tổng kết	49
4.1	Kết quả	49
4.1.1	Kết quả đánh giá bằng OpenSCAP	50
4.1.2	Kết quả đánh giá bằng Lynis	63
4.1.3	Các thành tựu	63
4.2	Hạn chế và hướng phát triển	63
4.2.1	Hạn chế	63
4.2.2	Hướng phát triển	64
4.3	Kết luận	64

Chương 1

Tổng quan hệ thống

1.1 Tổng quan CIS

CIS (Center for Internet Security) là tổ chức phi lợi nhuận phát triển các tiêu chuẩn bảo mật được công nhận rộng rãi trong ngành công nghệ thông tin. CIS Benchmarks cung cấp các hướng dẫn cấu hình chi tiết để bảo mật hệ thống theo best practices.

CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0 là tài liệu tham chiếu chứa 188 đề xuất cấu hình bảo mật cho Ubuntu Server 24.04 LTS. Các đề xuất được phân loại theo 7 nhóm chính và đánh giá theo 2 trạng thái:

- **Automated:** Các khuyến nghị có thể tự động hóa việc đánh giá và xác nhận trạng thái đạt/không đạt
- **Manual:** Các khuyến nghị yêu cầu các bước thủ công để xác thực vì trạng thái cấu hình có thể thay đổi tùy thuộc vào môi trường cụ thể

1.2 Tổng quan Linux

Ubuntu Server 24.04 LTS là phiên bản Long Term Support mới nhất, cung cấp nền tảng ổn định và an toàn cho môi trường production. Với kernel Linux 6.8 và các cải tiến bảo mật tích hợp, Ubuntu 24.04 LTS là lựa chọn lý tưởng cho triển khai các tiêu chuẩn bảo mật CIS.

Kiến trúc bảo mật Linux bao gồm nhiều lớp bảo vệ từ kernel level đến application level. Việc hardening hệ thống Linux đòi hỏi kiến thức sâu về:

- Kernel modules và filesystem security
- Network protocols và firewall configuration
- Access control và authentication mechanisms
- Logging và auditing systems
- System maintenance và file permissions

1.2.1 Manual Hardening

Phương pháp manual hardening đòi hỏi người quản trị thực hiện từng bước kiểm tra và cấu hình thủ công. Mặc dù tốn thời gian hơn, phương pháp này cung cấp sự linh hoạt cao và kiểm soát chi tiết.

STT	Tên khuyến nghị
1	Ensure unused filesystems kernel modules are not available
2	Ensure GPG keys are configured
3	Ensure package manager repositories are configured
4	Ensure updates, patches, and additional security software are installed
5	Ensure only approved services are listening on a network interface
6	Ensure IPv6 status is identified
7	Ensure ufw outbound connections are configured
8	Ensure iptables are flushed with nftables
9	Ensure nftables outbound and established connections are configured
10	Ensure iptables outbound and established connections are configured
11	Ensure ip6tables outbound and established connections are configured
12	Ensure password complexity is configured
13	Ensure minimum password days is configured
14	Ensure journald log file access is configured
15	Ensure journald log file rotation is configured
16	Ensure systemd-journal-upload authentication is configured
17	Ensure rsyslog logging is configured
18	Ensure rsyslog is configured to send logs to a remote log host
19	Ensure rsyslog is not configured to receive logs from a remote client
20	Ensure logrotate is configured
21	Ensure running and on disk configuration is same
22	Ensure SUID and SGID files are reviewed

Bảng 1.1: Danh sách các khuyến nghị CIS yêu cầu đánh giá thủ công

1.2.2 Automated Hardening

Phương pháp automation với Ansible cho phép thực hiện hàng loạt các kiểm tra và cấu hình bảo mật một cách tự động, nhất quán và có thể tái sử dụng. Ansible cung cấp các module mạnh mẽ để tương tác với hệ thống Linux.

STT	Tên khuyến nghị	Module
1	Ensure cramfs kernel module is not available	modprobe
2	Ensure freevxfs kernel module is not available	modprobe
3	Ensure hfs kernel module is not available	modprobe
4	Ensure hfsplus kernel module is not available	modprobe
5	Ensure jffs2 kernel module is not available	modprobe
6	Ensure overlayfs kernel module is not available	modprobe
7	Ensure squashfs kernel module is not available	modprobe
8	Ensure udf kernel module is not available	modprobe
9	Ensure usb-storage kernel module is not available	modprobe
10	Ensure /tmp is a separate partition	parted
11	Ensure nodev option set on /tmp partition	mount
12	Ensure nosuid option set on /tmp partition	mount
13	Ensure noexec option set on /tmp partition	mount
14	Ensure /dev/shm is a separate partition	parted
15	Ensure nodev option set on /dev/shm partition	mount
16	Ensure nosuid option set on /dev/shm partition	mount
17	Ensure noexec option set on /dev/shm partition	mount
18	Ensure separate partition exists for /home	parted
19	Ensure nodev option set on /home partition	mount
20	Ensure nosuid option set on /home partition	mount
21	Ensure separate partition exists for /var	parted
22	Ensure nodev option set on /var partition	mount
23	Ensure nosuid option set on /var partition	mount
24	Ensure separate partition exists for /var/tmp	parted
25	Ensure nodev option set on /var/tmp partition	mount
26	Ensure nosuid option set on /var/tmp partition	mount
27	Ensure noexec option set on /var/tmp partition	mount
28	Ensure separate partition exists for /var/log	parted
29	Ensure nodev option set on /var/log partition	mount
30	Ensure nosuid option set on /var/log partition	mount
31	Ensure noexec option set on /var/log partition	mount
32	Ensure separate partition exists for /var/log/audit	parted

STT	Tên khuyến nghị	Module
33	Ensure nodev option set on /var/log/audit partition	mount
34	Ensure nosuid option set on /var/log/audit partition	mount
35	Ensure noexec option set on /var/log/audit partition	mount
36	Ensure AppArmor is installed	apt
37	Ensure AppArmor is enabled in the bootloader configuration	lineinfile
38	Ensure all AppArmor Profiles are in enforce or complain mode	command
39	Ensure all AppArmor Profiles are enforcing	command
40	Ensure bootloader password is set	lineinfile
41	Ensure access to bootloader config is configured	file
42	Ensure address space layout randomization is enabled	sysctl
43	Ensure ptrace_scope is restricted	sysctl
44	Ensure core dumps are restricted	sysctl
45	Ensure prelink is not installed	apt
46	Ensure Automatic Error Reporting is not enabled	lineinfile
47	Ensure message of the day is configured properly	copy
48	Ensure local login warning banner is configured properly	copy
49	Ensure remote login warning banner is configured properly	copy
50	Ensure access to /etc/motd is configured	file
51	Ensure access to /etc/issue is configured	file
52	Ensure access to /etc/issue.net is configured	file
53	Ensure GDM is removed	apt
54	Ensure GDM login banner is configured	lineinfile
55	Ensure GDM disable-user-list option is enabled	lineinfile
56	Ensure GDM screen locks when the user is idle	lineinfile
57	Ensure GDM screen locks cannot be overridden	lineinfile
58	Ensure GDM automatic mounting of removable media is disabled	lineinfile
59	Ensure GDM disabling automatic mounting of removable media is not overridden	lineinfile
60	Ensure GDM autorun-never is enabled	lineinfile
61	Ensure GDM autorun-never is not overridden	lineinfile
62	Ensure XDMCP is not enabled	lineinfile
63	Ensure autofs services are not in use	service
64	Ensure avahi daemon services are not in use	service

STT	Tên khuyến nghị	Module
65	Ensure dhcp server services are not in use	service
66	Ensure dns server services are not in use	service
67	Ensure dnsmasq services are not in use	service
68	Ensure ftp server services are not in use	service
69	Ensure ldap server services are not in use	service
70	Ensure message access server services are not in use	service
71	Ensure network file system services are not in use	service
72	Ensure nis server services are not in use	service
73	Ensure print server services are not in use	service
74	Ensure rpcbind services are not in use	service
75	Ensure rsync services are not in use	service
76	Ensure samba file server services are not in use	service
77	Ensure snmp services are not in use	service
78	Ensure tftp server services are not in use	service
79	Ensure web proxy server services are not in use	service
80	Ensure web server services are not in use	service
81	Ensure xinetd services are not in use	service
82	Ensure X window server services are not in use	service
83	Ensure mail transfer agent is configured for local-only mode	lineinfile
84	Ensure NIS Client is not installed	apt
85	Ensure rsh client is not installed	apt
86	Ensure talk client is not installed	apt
87	Ensure telnet client is not installed	apt
88	Ensure ldap client is not installed	apt
89	Ensure ftp client is not installed	apt
90	Ensure a single time synchronization daemon is in use	service
91	Ensure systemd-timesyncd configured with authorized timeserver	lineinfile
92	Ensure systemd-timesyncd is enabled and running	service
93	Ensure chrony is configured with authorized timeserver	lineinfile
94	Ensure chrony is running as user _chrony	user
95	Ensure chrony is enabled and running	service
96	Ensure cron daemon is enabled and active	service

STT	Tên khuyến nghị	Module
97	Ensure permissions on /etc/crontab are configured	file
98	Ensure permissions on /etc/cron.hourly are configured	file
99	Ensure permissions on /etc/cron.daily are configured	file
100	Ensure permissions on /etc/cron.weekly are configured	file
101	Ensure permissions on /etc/cron.monthly are configured	file
102	Ensure permissions on /etc/cron.d are configured	file
103	Ensure crontab is restricted to authorized users	file
104	Ensure at is restricted to authorized users	file
105	Ensure wireless interfaces are disabled	service
106	Ensure bluetooth services are not in use	service
107	Ensure dccp kernel module is not available	modprobe
108	Ensure tipc kernel module is not available	modprobe
109	Ensure rds kernel module is not available	modprobe
110	Ensure sctp kernel module is not available	modprobe
111	Ensure ip forwarding is disabled	sysctl
112	Ensure packet redirect sending is disabled	sysctl
113	Ensure bogus icmp responses are ignored	sysctl
114	Ensure broadcast icmp requests are ignored	sysctl
115	Ensure icmp redirects are not accepted	sysctl
116	Ensure secure icmp redirects are not accepted	sysctl
117	Ensure reverse path filtering is enabled	sysctl
118	Ensure source routed packets are not accepted	sysctl
119	Ensure suspicious packets are logged	sysctl
120	Ensure tcp syn cookies is enabled	sysctl
121	Ensure ipv6 router advertisements are not accepted	sysctl
122	Ensure a single firewall configuration utility is in use	apt
123	Ensure ufw is installed	apt
124	Ensure iptables-persistent is not installed with ufw	apt
125	Ensure ufw service is enabled	service
126	Ensure ufw loopback traffic is configured	ufw
127	Ensure ufw firewall rules exist for all open ports	ufw
128	Ensure ufw default deny firewall policy	ufw

STT	Tên khuyến nghị	Module
129	Ensure nftables is installed	apt
130	Ensure ufw is uninstalled or disabled with nftables	service
131	Ensure a nftables table exists	nftables
132	Ensure nftables base chains exist	nftables
133	Ensure nftables loopback traffic is configured	nftables
134	Ensure nftables default deny firewall policy	nftables
135	Ensure nftables service is enabled	service
136	Ensure nftables rules are permanent	copy
137	Ensure iptables packages are installed	apt
138	Ensure nftables is not in use with iptables	service
139	Ensure ufw is not in use with iptables	service
140	Ensure iptables default deny firewall policy	iptables
141	Ensure iptables loopback traffic is configured	iptables
142	Ensure iptables firewall rules exist for all open ports	iptables
143	Ensure ip6tables default deny firewall policy	iptables
144	Ensure ip6tables loopback traffic is configured	iptables
145	Ensure ip6tables firewall rules exist for all open ports	iptables
146	Ensure permissions on /etc/ssh/sshd_config are configured	file
147	Ensure permissions on SSH private host key files are configured	file
148	Ensure permissions on SSH public host key files are configured	file
149	Ensure sshd access is configured	lineinfile
150	Ensure sshd Banner is configured	lineinfile
151	Ensure sshd Ciphers are configured	lineinfile
152	Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured	lineinfile
153	Ensure sshd DisableForwarding is enabled	lineinfile
154	Ensure sshd GSSAPIAuthentication is disabled	lineinfile
155	Ensure sshd HostbasedAuthentication is disabled	lineinfile
156	Ensure sshd IgnoreRhosts is enabled	lineinfile
157	Ensure sshd KexAlgorithms is configured	lineinfile
158	Ensure sshd LoginGraceTime is configured	lineinfile
159	Ensure sshd LogLevel is configured	lineinfile
160	Ensure sshd MACs are configured	lineinfile

STT	Tên khuyến nghị	Module
161	Ensure sshd MaxAuthTries is configured	lineinfile
162	Ensure sshd MaxSessions is configured	lineinfile
163	Ensure sshd MaxStartups is configured	lineinfile
164	Ensure sshd PermitEmptyPasswords is disabled	lineinfile
165	Ensure sshd PermitRootLogin is disabled	lineinfile
166	Ensure sshd PermitUserEnvironment is disabled	lineinfile
167	Ensure sshd UsePAM is enabled	lineinfile
168	Ensure sudo is installed	apt
169	Ensure sudo commands use pty	lineinfile
170	Ensure sudo log file exists	file
171	Ensure users must provide password for privilege escalation	lineinfile
172	Ensure re-authentication for privilege escalation is not disabled globally	lineinfile
173	Ensure sudo authentication timeout is configured correctly	lineinfile
174	Ensure access to the su command is restricted	lineinfile
175	Ensure latest version of pam is installed	apt
176	Ensure libpam-modules is installed	apt
177	Ensure libpam-pwquality is installed	apt
178	Ensure pam_unix module is enabled	lineinfile
179	Ensure pam_faillock module is enabled	lineinfile
180	Ensure pam_pwquality module is enabled	lineinfile
181	Ensure pam_pwhistory module is enabled	lineinfile
182	Ensure password failed attempts lockout is configured	lineinfile
183	Ensure password unlock time is configured	lineinfile
184	Ensure password failed attempts lockout includes root account	lineinfile
185	Ensure password number of changed characters is configured	lineinfile
186	Ensure minimum password length is configured	lineinfile
187	Ensure password same consecutive characters is configured	lineinfile
188	Ensure password maximum sequential characters is configured	lineinfile
189	Ensure password dictionary check is enabled	lineinfile
190	Ensure password quality checking is enforced	lineinfile
191	Ensure password quality is enforced for the root user	lineinfile
192	Ensure password history remember is configured	lineinfile

STT	Tên khuyến nghị	Module
193	Ensure password history is enforced for the root user	lineinfile
194	Ensure pam_pwhistory includes use_authok	lineinfile
195	Ensure pam_unix does not include nullok	lineinfile
196	Ensure pam_unix does not include remember	lineinfile
197	Ensure pam_unix includes a strong password hashing algorithm	lineinfile
198	Ensure pam_unix includes use_authok	lineinfile
199	Ensure password expiration is configured	lineinfile
200	Ensure password expiration warning days is configured	lineinfile
201	Ensure strong password hashing algorithm is configured	lineinfile
202	Ensure inactive password lock is configured	lineinfile
203	Ensure all users last password change date is in the past	lineinfile
204	Ensure root is the only UID 0 account	lineinfile
205	Ensure root is the only GID 0 account	lineinfile
206	Ensure group root is the only GID 0 group	lineinfile
207	Ensure root account access is controlled	lineinfile
208	Ensure root path integrity	lineinfile
209	Ensure root user umask is configured	lineinfile
210	Ensure system accounts do not have a valid login shell	lineinfile
211	Ensure accounts without a valid login shell are locked	lineinfile
212	Ensure nologin is not listed in /etc/shells	lineinfile
213	Ensure default user shell timeout is configured	lineinfile
214	Ensure default user umask is configured	lineinfile
215	Ensure journald service is enabled and active	service
216	Ensure only one logging system is in use	service
217	Ensure systemd-journal-remote is installed	apt
218	Ensure systemd-journal-upload is enabled and active	service
219	Ensure systemd-journal-remote service is not in use	service
220	Ensure journald ForwardToSyslog is disabled	lineinfile
221	Ensure journald Compress is configured	lineinfile
222	Ensure journald Storage is configured	lineinfile
223	Ensure rsyslog is installed	apt
224	Ensure rsyslog service is enabled and active	service

STT	Tên khuyến nghị	Module
225	Ensure journald is configured to send logs to rsyslog	lineinfile
226	Ensure rsyslog log file creation mode is configured	lineinfile
227	Ensure rsyslog is not configured to receive logs from a remote client	lineinfile
228	Ensure access to all logfiles has been configured	lineinfile
229	Ensure auditd packages are installed	apt
230	Ensure auditd service is enabled and active	service
231	Ensure auditing for processes that start prior to auditd is enabled	lineinfile
232	Ensure audit_backlog_limit is sufficient	sysctl
233	Ensure audit log storage size is configured	lineinfile
234	Ensure audit logs are not automatically deleted	lineinfile
235	Ensure system is disabled when audit logs are full	lineinfile
236	Ensure system warns when audit logs are low on space	lineinfile
237	Ensure changes to system administration scope (sudoers) is collected	lineinfile
238	Ensure actions as another user are always logged	lineinfile
239	Ensure events that modify the sudo log file are collected	lineinfile
240	Ensure events that modify date and time information are collected	lineinfile
241	Ensure events that modify the system's network environment are collected	lineinfile
242	Ensure use of privileged commands are collected	lineinfile
243	Ensure unsuccessful file access attempts are collected	lineinfile
244	Ensure events that modify user/group information are collected	lineinfile
245	Ensure discretionary access control permission modification events are collected	lineinfile
246	Ensure successful file system mounts are collected	lineinfile
247	Ensure session initiation information is collected	lineinfile
248	Ensure login and logout events are collected	lineinfile
249	Ensure file deletion events by users are collected	lineinfile
250	Ensure events that modify the system's Mandatory Access Controls are collected	lineinfile
251	Ensure successful and unsuccessful attempts to use the chcon command are collected	lineinfile
252	Ensure successful and unsuccessful attempts to use the setfacl command are collected	lineinfile
253	Ensure successful and unsuccessful attempts to use the chacl command are collected	lineinfile
254	Ensure successful and unsuccessful attempts to use the usermod command are collected	lineinfile
255	Ensure kernel module loading unloading and modification is collected	lineinfile

STT	Tên khuyến nghị	Module
256	Ensure the audit configuration is immutable	lineinfile
257	Ensure audit log files mode is configured	file
258	Ensure audit log files owner is configured	file
259	Ensure audit log files group owner is configured	file
260	Ensure the audit log file directory mode is configured	file
261	Ensure audit configuration files mode is configured	file
262	Ensure audit configuration files owner is configured	file
263	Ensure audit configuration files group owner is configured	file
264	Ensure audit tools mode is configured	file
265	Ensure audit tools owner is configured	file
266	Ensure audit tools group owner is configured	file
267	Ensure AIDE is installed	apt
268	Ensure filesystem integrity is regularly checked	service
269	Ensure cryptographic mechanisms are used to protect the integrity of audit tools	lineinfile
270	Ensure permissions on /etc/passwd are configured	file
271	Ensure permissions on /etc/passwd- are configured	file
272	Ensure permissions on /etc/group are configured	file
273	Ensure permissions on /etc/group- are configured	file
274	Ensure permissions on /etc/shadow are configured	file
275	Ensure permissions on /etc/shadow- are configured	file
276	Ensure permissions on /etc/gshadow are configured	file
277	Ensure permissions on /etc/gshadow- are configured	file
278	Ensure permissions on /etc/shells are configured	file
279	Ensure permissions on /etc/security/opasswd are configured	file
280	Ensure world writable files and directories are secured	command
281	Ensure no files or directories without an owner and a group exist	command
282	Ensure accounts in /etc/passwd use shadowed passwords	lineinfile
283	Ensure /etc/shadow password fields are not empty	lineinfile
284	Ensure all groups in /etc/passwd exist in /etc/group	lineinfile
285	Ensure shadow group is empty	lineinfile
286	Ensure no duplicate UIDs exist	lineinfile
287	Ensure no duplicate GIDs exist	lineinfile

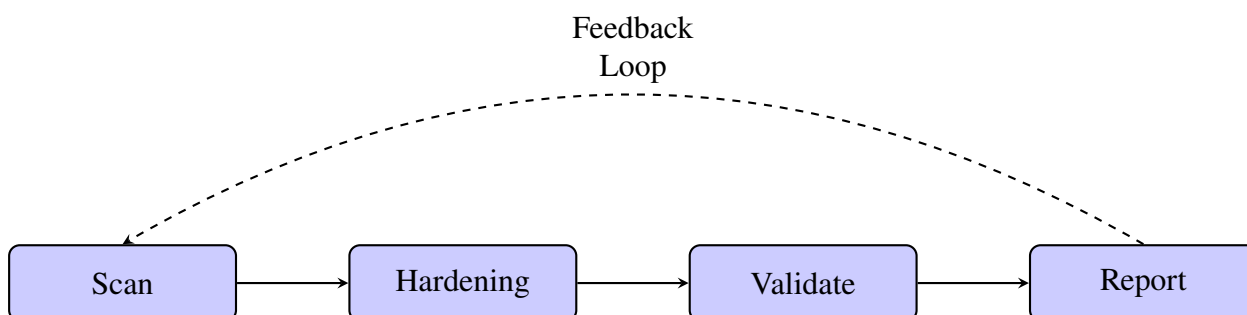
STT	Tên khuyến nghị	Module
288	Ensure no duplicate user names exist	lineinfile
289	Ensure no duplicate group names exist	lineinfile
290	Ensure local interactive user home directories are configured	lineinfile
291	Ensure local interactive user dot files access is configured	lineinfile

Bảng 1.2: Danh sách các khuyến nghị CIS có thể tự động hóa

Chương 2

Phương pháp triển khai

2.1 Quy trình tổng thể



Hình 2.1: Quy trình 4 bước triển khai bảo mật hệ thống

Quy trình triển khai bảo mật được thiết kế theo chu trình 4 bước chính, đảm bảo tính toàn diện và có thể lặp lại. Mỗi bước có vai trò cụ thể và liên kết chặt chẽ với nhau để tạo ra một hệ thống bảo mật hoàn chỉnh.

Quy trình này bắt đầu từ việc đánh giá trạng thái hiện tại, tiếp theo là áp dụng các biện pháp hardening, sau đó xác thực kết quả và cuối cùng là tạo báo cáo chi tiết. Vòng lặp này giúp đảm bảo hệ thống luôn được cập nhật và tuân thủ các tiêu chuẩn bảo mật mới nhất.

2.2 Phương pháp tiếp cận

2.2.1 Manual Configuration

Cấu hình thủ công là phương pháp truyền thống trong quản trị hệ thống, trong đó administrator trực tiếp thực hiện các thay đổi thông qua dòng lệnh (CLI), giao diện đồ họa (GUI) hoặc chỉnh sửa các file cấu hình.

Cấu hình qua CLI (Command Line Interface)

Administrator sử dụng các lệnh trực tiếp trên terminal để cài đặt và cấu hình hệ thống, ví dụ:

- Cài đặt package: `apt install`, `apt update`

- Quản lý dịch vụ: `systemctl start/stop/enable`
- Cấu hình firewall: `ufw allow, ufw enable`
- Phân quyền file: `chmod, chown`

Phương pháp này cho phép kiểm soát chi tiết từng bước, tuy nhiên dễ xảy ra sai sót khi thực hiện lặp lại trên nhiều hệ thống.

Cấu hình qua GUI (Graphical User Interface)

Một số tác vụ như quản lý người dùng, cấu hình dịch vụ hoặc firewall có thể được thực hiện thông qua giao diện đồ họa. Tuy nhiên, phương pháp này phụ thuộc vào thao tác thủ công, khó tự động hóa và không phù hợp với môi trường server hoặc hệ thống quy mô lớn.

Chỉnh sửa file cấu hình

Administrator chỉnh sửa trực tiếp các file cấu hình hệ thống bằng các trình soạn thảo như vim, nano. Ví dụ:

- `/etc/ssh/sshd_config`
- `/etc/sysctl.conf`
- `/etc/fstab`

Phương pháp này linh hoạt và mạnh mẽ, nhưng dễ gây lỗi cú pháp, khó kiểm soát thay đổi và không đảm bảo tính nhất quán giữa các hệ thống.

Đánh giá

Phương pháp cấu hình thủ công có ưu điểm là linh hoạt và cho phép kiểm soát chi tiết. Tuy nhiên, nhược điểm là tốn thời gian, dễ xảy ra sai sót và khó đảm bảo tính nhất quán khi triển khai trên nhiều hệ thống. Do đó, phương pháp này chỉ phù hợp với các hệ thống nhỏ hoặc các tác vụ yêu cầu can thiệp chuyên sâu.

2.2.2 Automation Configuration

Ansible là công cụ tự động hóa giúp loại bỏ các thao tác thủ công lặp lại. Toàn bộ quy trình cấu hình và hardening có thể được định nghĩa dưới dạng mã (Infrastructure as Code), từ đó đảm bảo tính nhất quán và khả năng tái sử dụng.

Ansible sử dụng định dạng YAML để xây dựng playbook, giúp dễ đọc và dễ bảo trì. Đặc biệt, cơ chế *idempotent* đảm bảo việc thực thi nhiều lần không gây ra trạng thái không mong muốn. Ngoài ra, Ansible hoạt động theo mô hình *agentless*, chỉ yêu cầu SSH và Python trên máy mục tiêu.

Tự động hóa thao tác CLI

Các lệnh CLI thủ công được chuyển thành các module tương ứng trong Ansible:

Manual CLI	Module	Mô tả
apt install	apt	Cài đặt package
systemctl	service/systemd	Quản lý dịch vụ
ufw	ufw	Cấu hình firewall
chmod, chown	file	Phân quyền file/thư mục

Các thao tác được định nghĩa thành task trong playbook và có thể thực thi đồng thời trên nhiều máy.

Tự động hóa thao tác GUI

Các thao tác GUI được chuyển thành cấu hình bằng code:

Manual GUI	Module	Mô tả
Tạo user	user	Quản lý người dùng
Quản lý group	group	Quản lý nhóm
Bật/tắt service	service	Điều khiển dịch vụ
Firewall	ufw/firewalld	Cấu hình firewall

Việc này giúp loại bỏ thao tác thủ công và chuẩn hóa cấu hình trên toàn hệ thống.

Tự động hóa chỉnh sửa file cấu hình

Thay vì chỉnh sửa thủ công, Ansible cung cấp các module để quản lý file cấu hình:

Manual	Module	Mô tả
Sửa từng dòng	lineinfile	Thay đổi một dòng cụ thể
Thêm block	blockinfile	Thêm đoạn cấu hình
Copy file	copy	Sao chép file cấu hình
Template	template	Sinh cấu hình động (Jinja2)

Cách tiếp cận này giúp kiểm soát cấu hình tốt hơn, hỗ trợ version hóa và giảm lỗi cú pháp.

Ví dụ minh họa

Thực hiện thủ công:

```
apt install nginx
systemctl enable nginx
systemctl start nginx
```

Sử dụng Ansible:

```
- name: Install and start nginx
  hosts: all
  become: true
  tasks:
    - name: Install nginx
      apt:
        name: nginx
        state: present

    - name: Enable and start nginx
      service:
        name: nginx
        state: started
        enabled: true
```

Kết luận

Việc chuyển đổi từ cấu hình thủ công sang tự động hóa giúp:

- Giảm thiểu lỗi do con người
- Đảm bảo tính nhất quán
- Dễ dàng mở rộng hệ thống
- Tăng khả năng tái sử dụng

2.3 Thiết kế hệ thống Ansible

2.3.1 Inventory

Inventory là thành phần cơ bản của Ansible, dùng để định nghĩa danh sách các máy chủ mục tiêu. Inventory có thể được xây dựng dưới dạng file INI, YAML, hoặc sử dụng *dynamic inventory* từ các nguồn như cloud providers. Trong dự án này, inventory được tổ chức theo nhóm máy chủ nhằm thuận tiện cho việc quản lý và áp dụng các chính sách khác nhau cho từng nhóm. Mỗi nhóm có thể được gán các biến riêng phù hợp với vai trò và yêu cầu bảo mật cụ thể.

Ngoài ra, inventory hỗ trợ định nghĩa biến toàn cục (*group variables*) và biến riêng cho từng host (*host variables*), giúp linh hoạt trong việc cấu hình môi trường triển khai đa dạng.

2.3.2 Playbooks

Playbook là tập hợp các task được định nghĩa theo thứ tự thực thi. Mỗi playbook có thể chứa một hoặc nhiều *play*, trong đó mỗi play áp dụng cho một nhóm host cụ thể và thực hiện các task thông qua các module của Ansible. Trong dự án này, các playbook được phân chia theo các chức năng chính:

- **Scanning:** Thu thập thông tin hệ thống và kiểm tra tuân thủ (compliance)
- **Hardening:** Áp dụng các chính sách bảo mật
- **Validation:** Kiểm tra lại trạng thái sau khi cấu hình
- **Reporting:** Tổng hợp và xuất báo cáo

Các playbook sử dụng các cơ chế như *conditional logic* (`when`), *handlers*, và *error handling* (`ignore_errors`, `failed_when`) nhằm đảm bảo tính ổn định và khả năng tự phục hồi khi xảy ra lỗi.

Các module sử dụng trong Playbooks

Trong quá trình triển khai, các playbook sử dụng nhiều module khác nhau để thực hiện các tác vụ cụ thể:

- **Quản lý package:** `apt`, `package` → Cài đặt, cập nhật và gỡ bỏ phần mềm
- **Quản lý dịch vụ:** `service`, `systemd` → Bật, tắt và kiểm soát trạng thái dịch vụ
- **Quản lý file và cấu hình:** `file`, `copy`, `template`, `lineinfile` → Phân quyền, sao chép và chỉnh sửa file cấu hình
- **Quản lý người dùng:** `user`, `group` → Tạo, xóa và cấu hình user/group
- **Cấu hình mạng và firewall:** `ufw`, `firewalld` → Thiết lập các rule bảo mật mạng
- **Thu thập thông tin:** `setup`, `command`, `shell` → Lấy thông tin hệ thống và thực thi lệnh
- **Kiểm tra và xác thực:** `stat`, `assert` → Kiểm tra trạng thái file và validate cấu hình

Việc sử dụng đa dạng các module giúp playbook có khả năng tự động hóa toàn diện và giảm thiểu sự phụ thuộc vào các lệnh thủ công.

2.3.3 Roles

Roles là phương pháp tổ chức mã nguồn Ansible theo hướng module hóa, giúp tăng khả năng tái sử dụng và dễ bảo trì. Mỗi role tuân theo một cấu trúc thư mục chuẩn bao gồm: `tasks`, `handlers`, `templates`, `files`, `vars`, `defaults`, và `meta`.

Trong dự án này, các role được phân chia theo các nhóm chức năng bảo mật như:

- **filesystem:** Quản lý phân vùng và quyền truy cập

- **network:** Cấu hình mạng và firewall
- **services:** Quản lý dịch vụ hệ thống
- **users:** Quản lý người dùng và phân quyền
- **logging:** Thiết lập logging và auditing
- **monitoring:** Giám sát hệ thống

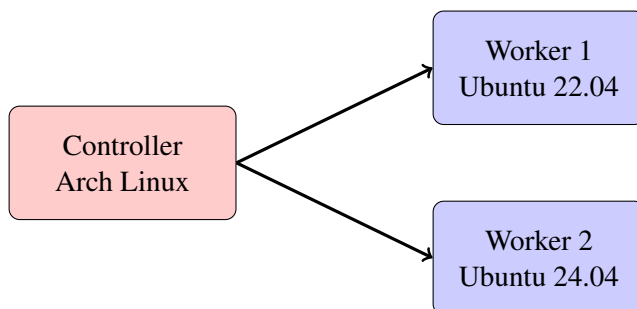
Mỗi role chịu trách nhiệm cho một lĩnh vực cụ thể trong quá trình hardening hệ thống.

Việc sử dụng roles giúp hệ thống dễ dàng mở rộng, cập nhật và tái sử dụng giữa các dự án khác nhau, đồng thời đảm bảo tính nhất quán trong việc triển khai các chính sách bảo mật.

Chương 3

Triển khai

3.1 Mô hình triển khai



Hình 3.1: Mô hình triển khai Controller–Workers

Hệ thống được triển khai theo mô hình *Controller–Workers*, trong đó máy Controller đóng vai trò trung tâm điều phối, thực thi các playbook Ansible và quản lý cấu hình. Các Worker là các máy mục tiêu nhận cấu hình thông qua kết nối SSH và thực thi các task tương ứng.

Mô hình này cho phép quản lý tập trung, hỗ trợ triển khai đồng thời trên nhiều hệ thống và đảm bảo tính nhất quán trong quá trình cấu hình.

Tên	Phiên bản	IP	Các gói cài đặt
Controller	2026.02.01	192.168.1.10	Core: Ansible KVM: qemu-kvm, libvirt-daemon-system, libvirt-clients, bridge-utils, virtinst Cloud-init: cloud-image-utils, genisoimage Base images: ubuntu-22.04.qcow2, ubuntu-24.04.qcow2
Worker 1	Ubuntu 22.04	192.168.1.11	Ban đầu: OpenSSH, Python3 Phase 1: apparmor, apparmor-utils Phase 2: fail2ban, libpam-tmpdir, debsums Phase 5: libpam-modules, libpam-pwquality, sudo Phase 6: auditd, audispd-plugins, rsyslog, aide Phase 7: systemd-journal-remote Security: lynis, chkrootkit, rkhunter, wget, unzip
Worker 2	Ubuntu 24.04	192.168.1.12	Ban đầu: OpenSSH, Python3 Phase 1: apparmor, apparmor-utils Phase 2: fail2ban, libpam-tmpdir, debsums Phase 5: libpam-modules, libpam-pwquality, sudo Phase 6: auditd, audispd-plugins, rsyslog, aide Phase 7: systemd-journal-remote Security: lynis, chkrootkit, rkhunter, wget, unzip

Bảng 3.1: Thông tin chi tiết các máy trong mô hình và các gói được cài đặt

3.1.1 Quy trình Automated Security Hardening

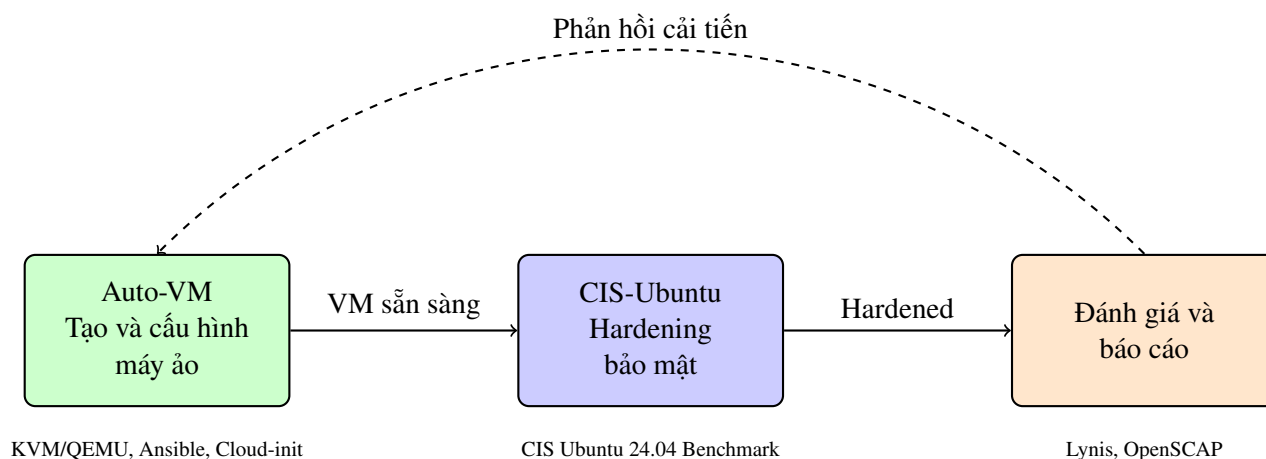
Dựa trên mô hình triển khai đã trình bày ở Hình 3.1, quy trình *Automated Security Hardening* được xây dựng nhằm tự động hóa việc triển khai và đánh giá bảo mật hệ thống.

Quy trình hoạt động của hệ thống diễn ra theo chu trình khép kín:

- Auto-VM khởi tạo môi trường và cung cấp các Worker sẵn sàng

- CIS-Ubuntu thực hiện hardening theo tiêu chuẩn bảo mật
- Report Module đánh giá và phát hiện các điểm chưa đạt
- Kết quả được phản hồi để cải tiến cấu hình trong các lần triển khai tiếp theo

Cách tiếp cận này giúp tự động hóa toàn bộ vòng đời bảo mật hệ thống, từ khởi tạo, cấu hình đến đánh giá và tối ưu hóa.



Hình 3.2: Mô hình Automated Security Hardening System

3.2 Manual

3.2.1 Initial Setup

Cài đặt các gói bảo mật cơ bản:

```

sudo apt update && sudo apt upgrade -y
sudo apt install -y apparmor apparmor-utils \
    fail2ban \
    debsums \
    auditd audispd-plugins \
    aide \
    rsyslog \
    libpam-pwquality \
    libpam-modules \
    sudo \
    systemd-journal-remote
# Cập nhật hệ thống
# Framework bảo mật AppArmor
# Bảo vệ SSH khỏi brute-force
# Kiểm tra integrity packages
# Hệ thống audit logs
# Intrusion detection system
# Centralized logging
# Password quality enforcement
# PAM authentication modules
# Privilege management
# Remote journal logging

```

Cấu hình AppArmor:

```

sudo systemctl enable apparmor          # Kích hoạt AppArmor boot
sudo systemctl start apparmor           # Khởi động AppArmor service
sudo aa-enforce /etc/apparmor.d/*       # Enforce tất cả profiles

```

```

sudo tee -a /etc/default/grub > /dev/null <<EOF
apparmor=1 security=apparmor
EOF

```

```

sudo update-grub                        # Cập nhật bootloader

```

Cấu hình filesystem security:

```

sudo mount -o remount,nodev,nosuid,noexec /tmp          # Bảo vệ /tmp directory
sudo mount -o remount,nodev,nosuid,noexec /dev/shm      # Bảo vệ shared memory

```

```

sudo tee -a /etc/fstab > /dev/null <<EOF
tmpfs /var/tmp tmpfs defaults,nodev,nosuid,noexec 0 0
EOF

```

```

sudo mount -a                                # Mount lại filesystems

```

Cấu hình login banners:

```

sudo tee /etc/issue /etc/issue.net /etc/motd > /dev/null <<EOF
Authorized uses only. All activity may be monitored and reported.
EOF

```

```

sudo chmod 644 /etc/issue /etc/issue.net /etc/motd      # Set permissions

```

```

sudo tee -a /etc/ssh/sshd_config > /dev/null <<EOF
Banner /etc/issue.net
EOF

```

```

sudo systemctl restart sshd                    # Restart SSH service

```

Kết quả mong đợi:

- Hệ thống được cập nhật với các bản vá bảo mật mới nhất
- AppArmor được kích hoạt và enforce tất cả profiles
- Các thư mục tạm thời (/tmp, /dev/shm, /var/tmp) được bảo vệ với các tùy chọn bảo mật
- Login banners hiển thị cảnh báo bảo mật khi người dùng đăng nhập

- Các gói bảo mật cơ bản được cài đặt và sẵn sàng cấu hình

3.2.2 Services Configuration

Disable unnecessary services:

```

sudo systemctl stop telnet.socket telnet \           # Disable telnet services
sudo systemctl disable telnet.socket telnet
sudo systemctl stop rsh.socket rsh \                 # Disable rsh services
sudo systemctl disable rsh.socket rsh
sudo systemctl stop rlogin.socket rlogin \           # Disable rlogin services
sudo systemctl disable rlogin.socket rlogin
sudo systemctl stop ypbind && \                       # Disable NIS service
sudo systemctl disable ypbind
sudo systemctl stop tftp.socket tftp \               # Disable tftp services
sudo systemctl disable tftp.socket tftp
sudo systemctl stop isc-dhcp-server && \             # Disable DHCP server
sudo systemctl disable isc-dhcp-server
sudo systemctl stop slapd && \                       # Disable OpenLDAP
sudo systemctl disable slapd
sudo systemctl stop apache2 && \                     # Disable Apache web server
sudo systemctl disable apache2
sudo systemctl stop nfs-server && \                  # Disable NFS server
sudo systemctl disable nfs-server
sudo systemctl stop rpcbind && \                     # Disable RPC service
sudo systemctl disable rpcbind
sudo systemctl stop cups && \                        # Disable printing service
sudo systemctl disable cups
sudo systemctl stop avahi-daemon && \                # Disable mDNS responder
sudo systemctl disable avahi-daemon
sudo systemctl stop bluetooth && \                  # Disable Bluetooth service
sudo systemctl disable bluetooth

```

Configure fail2ban for intrusion prevention:

```

sudo apt install -y fail2ban                         # Install fail2ban
sudo systemctl enable fail2ban                       # Enable fail2ban boot
sudo systemctl start fail2ban                       # Start fail2ban service

cat << EOF | sudo tee /etc/fail2ban/jail.local       # Configure fail2ban
[DEFAULT]

```

```
bantime = 3600
findtime = 600
maxretry = 3
```

```
[sshd]
enabled = true
port = ssh
logpath = /var/log/auth.log
maxretry = 3
EOF
```

```
sudo systemctl restart fail2ban # Apply configuration
```

Configure time synchronization:

```
sudo apt install -y ntp # Install NTP service
sudo systemctl enable ntp # Enable NTP boot
sudo systemctl start ntp # Start NTP service
sudo timedatectl set-ntp true # Enable system time sync
```

Kết quả mong đợi:

- Các dịch vụ không cần thiết (telnet, rsh, rlogin, etc.) được vô hiệu hóa hoàn toàn
- Fail2ban được cấu hình để bảo vệ SSH khỏi tấn công brute-force
- Hệ thống được đồng bộ thời gian với NTP server
- Chỉ các dịch vụ cần thiết cho hoạt động được kích hoạt
- Giảm thiểu bề mặt tấn công (attack surface) của hệ thống

3.2.3 Network Security

Configure network kernel parameters:

```
sudo tee -a /etc/sysctl.d/99-cis.conf > /dev/null <<EOF
net.ipv4.ip_forward = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.icmp_ignore_bogus_error_responses = 1
net.ipv4.icmp_echo_ignore_broadcasts = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.secure_redirects = 0
net.ipv4.conf.all.rp_filter = 1
```

```
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.all.log_martians = 1
net.ipv4.tcp_syncookies = 1
net.ipv6.conf.all.accept_ra = 0
EOF
```

```
sudo sysctl -p /etc/sysctl.d/99-cis.conf # Apply all settings
```

Disable wireless services:

```
sudo systemctl stop wpa_supplicant # Stop wireless service
sudo systemctl disable wpa_supplicant # Disable wireless boot
sudo systemctl stop NetworkManager # Stop NetworkManager
sudo systemctl disable NetworkManager # Disable NetworkManager boot
```

Configure IPv6 status:

```
sudo tee -a /etc/sysctl.d/99-cis.conf > /dev/null <<EOF
net.ipv6.conf.all.disable_ipv6 = 1
net.ipv6.conf.default.disable_ipv6 = 1
EOF
```

```
sudo sysctl -p /etc/sysctl.d/99-cis.conf # Apply IPv6 settings
```

Kết quả mong đợi:

- Các tham số kernel mạng được cấu hình theo tiêu chuẩn bảo mật CIS
- IP forwarding bị vô hiệu hóa để ngăn chặn router functionality
- ICMP redirects và source routes bị chặn để chống lại spoofing attacks
- IPv6 được vô hiệu hóa nếu không sử dụng
- Các dịch vụ wireless không cần thiết được vô hiệu hóa
- TCP SYN cookies được kích hoạt để chống lại SYN flood attacks

3.2.4 Firewall Configuration

Configure UFW firewall:

```
sudo apt install -y ufw # Install UFW firewall
sudo apt remove --purge iptables-persistent # Remove conflicting firewall
sudo ufw enable # Enable firewall
sudo ufw default deny incoming # Default deny inbound
```

```

sudo ufw default allow outgoing      # Default allow outbound
sudo ufw allow in on lo              # Allow loopback traffic
sudo ufw allow 22/tcp                # Allow SSH access
sudo ufw allow 80/tcp                # Allow HTTP (if needed)
sudo ufw allow 443/tcp               # Allow HTTPS (if needed)
sudo ufw status verbose              # Check firewall status

```

Configure firewall logging:

```

sudo ufw logging on                  # Enable firewall logging
sudo ufw logging medium              # Set log level to medium
sudo tail -f /var/log/ufw.log        # Monitor firewall logs

```

Advanced firewall rules:

```

sudo ufw deny 23/tcp                # Block telnet
sudo ufw deny 135/tcp                # Block RPC
sudo ufw deny 139/tcp                # Block NetBIOS
sudo ufw deny 445/tcp                # Block SMB
sudo ufw deny 1433/tcp               # Block SQL Server
sudo ufw deny 3389/tcp               # Block RDP
sudo ufw reload                      # Apply all rules

```

Kết quả mong đợi:

- UFW firewall được kích hoạt và bảo vệ hệ thống
- Policy mặc định: deny inbound, allow outbound
- Các cổng nguy hiểm (telnet, RPC, NetBIOS, etc.) bị chặn
- Chỉ các cổng cần thiết (SSH, HTTP, HTTPS) được cho phép
- Logging được kích hoạt để monitor và audit traffic
- Loopback traffic được cho phép cho các dịch vụ nội bộ

3.2.5 Access Control

SSH Security Hardening:

```

sudo chmod 600 /etc/ssh/sshd_config # Secure SSH config
sudo chmod 600 /etc/ssh/ssh_host*_key # Secure private keys
sudo chmod 644 /etc/ssh/ssh_host*_key.pub # Secure public keys

sudo tee -a /etc/ssh/sshd_config > /dev/null <<EOF

```

```

PermitEmptyPasswords no
PermitRootLogin no
MaxAuthTries 3
MaxSessions 3
HostbasedAuthentication no
GSSAPIAuthentication no
ClientAliveInterval 300
ClientAliveCountMax 0
EOF

```

```

sudo systemctl restart sshd # Apply SSH changes

```

Configure PAM Password Quality:

```

sudo apt install -y libpam-pwquality # Install password quality

```

```

sudo tee -a /etc/pam.d/common-password > /dev/null <<EOF
password requisite pam_pwquality.so retry=3 \
minlen=8
ucredit=-1
lcredit=-1
dcredit=-1
ocredit=-1
EOF

```

```

sudo tee -a /etc/security/pwquality.conf > /dev/null <<EOF
minlen=8
ucredit=-1
lcredit=-1
dcredit=-1
ocredit=-1
EOF

```

Configure SUDO Security:

```

sudo tee -a /etc/sudoers.d/security > /dev/null <<EOF
Defaults timestamp_timeout=15
Defaults passwd_tries=3
Defaults use_pty
Defaults log_input, log_output
EOF

```

```
sudo chmod 440 /etc/sudoers.d/security # Secure sudoers file
```

Configure User Defaults:

```
sudo tee -a /etc/login.defs > /dev/null <<EOF
UMASK 077
PASS_MAX_DAYS 90
PASS_MIN_DAYS 1
PASS_WARN_AGE 7
LOGIN_RETRIES 5
LOGIN_TIMEOUT 60
EOF
```

Kết quả mong đợi:

- SSH được hardening với các thiết lập bảo mật tối đa
- Root login bị vô hiệu hóa, chỉ cho phép SSH key authentication
- Password quality enforcement được áp dụng với các yêu cầu phức tạp
- Sudo được cấu hình với logging và timeout hợp lý
- User defaults được cấu hình với các chính sách bảo mật chặt chẽ
- Các file SSH keys được bảo vệ với permissions phù hợp

3.2.6 Logging & Auditing

Configure auditd service:

```
sudo apt install -y auditd audispd-plugins # Install audit packages
sudo systemctl enable auditd # Enable auditd boot
sudo systemctl start auditd # Start auditd service
sudo tee /etc/default/grub.d/99-audit.cfg > /dev/null <<EOF
quiet splash audit=1 audit_backlog_limit=8192
EOF
sudo update-grub # Update bootloader
```

Configure auditd settings:

```
sudo tee -a /etc/audit/auditd.conf > /dev/null <<EOF
max_log_file = 8
max_log_file_action = suspend
space_left_action = single
```

```
admin_space_left_action = suspend
EOF
```

```
sudo systemctl restart auditd # Apply auditd changes
```

Configure journald and rsyslog:

```
sudo systemctl enable systemd-journald # Enable journald service
sudo systemctl start systemd-journald # Start journald service
sudo apt install -y rsyslog # Install rsyslog package
sudo systemctl enable rsyslog # Enable rsyslog service
sudo systemctl start rsyslog # Start rsyslog service
```

```
sudo tee -a /etc/systemd/journald.conf > /dev/null <<EOF
ForwardToSyslog=no
Compress=yes
Storage=persistent
EOF
```

```
sudo tee -a /etc/rsyslog.d/50-default.conf > /dev/null <<EOF
\${FileCreateMode} 0640
EOF
```

```
sudo chmod 0755 /var/log && \ # Secure log directory
sudo chown root:root /var/log
sudo systemctl restart systemd-journald rsyslog # Apply logging changes
```

Configure AIDE for file integrity:

```
sudo apt install -y aide # Install AIDE
sudo aide --init # Initialize AIDE database
sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db # Move initial database
sudo aide --check # Run integrity check
sudo crontab - > /dev/null <<EOF
0 2 * * * /usr/bin/aide --check
EOF
```

Kết quả mong đợi:

- Auditd được kích hoạt và cấu hình để monitor system events
- Logging system được thiết lập với persistent storage và appropriate permissions

- AIDE database được khởi tạo để monitor file integrity
- Daily integrity checks được schedule để phát hiện thay đổi bất thường
- Log files được bảo vệ với permissions phù hợp
- System events được ghi lại để phục vụ cho forensic analysis

3.2.7 System Maintenance

Configure critical system file permissions:

```
sudo chmod 0644 /etc/passwd /etc/passwd- /etc/group /etc/group- /etc/shells
sudo chown root:root /etc/passwd /etc/passwd- /etc/group /etc/group- /etc/shells
sudo chmod 0000 /etc/shadow /etc/shadow- /etc/gshadow /etc/gshadow-
sudo chown root:shadow /etc/shadow /etc/shadow- /etc/gshadow /etc/gshadow-
sudo chmod 0600 /etc/security/opasswd
sudo chown root:root /etc/security/opasswd
```

Find and secure world writable files:

```
find / -type f -perm -002 \                                # Find world writable files
    -not -path "/proc/*" \                                # Exclude /proc directory
    -not -path "/sys/*" \                                  # Exclude /sys directory
    -not -path "/dev/*" 2>/dev/null                       # Exclude /dev directory

find / -type d -perm -002 \                                # Find world writable dirs
    -not -path "/proc/*" \                                # Exclude /proc directory
    -not -path "/sys/*" \                                  # Exclude /sys directory
    -not -path "/dev/*" 2>/dev/null                       # Exclude /dev directory

chmod o-w /etc/passwd /etc/shadow /etc/group \           # Remove world write
    /etc/gshadow 2>/dev/null || true
```

Review SUID/SGID files:

```
find / -type f -perm -4000 \                                # Find SUID files
    -not -path "/proc/*" \                                # Exclude /proc directory
    -not -path "/sys/*" \                                  # Exclude /sys directory
    -not -path "/dev/*" 2>/dev/null                       # Exclude /dev directory

find / -type f -perm -2000 \                                # Find SGID files
    -not -path "/proc/*" \                                # Exclude /proc directory
    -not -path "/sys/*" \                                  # Exclude /sys directory
```

```

-not -path "/dev/*" 2>/dev/null # Exclude /dev directory

chmod 0755 /usr/bin/passwd 2>/dev/null || true # Secure passwd binary
chmod 0755 /usr/bin/gpasswd 2>/dev/null || true # Secure gpasswd binary
chmod 0755 /usr/bin/chsh 2>/dev/null || true # Secure chsh binary

Configure home directory permissions:

find /home -type d -exec chmod 0750 {} \; \ # Set directory permissions
    2>/dev/null || true
find /home -type f -exec chmod 0640 {} \; \ # Set file permissions
    2>/dev/null || true
chmod 0755 /home 2>/dev/null || true # Set home base permission

System integrity checks:

sudo debsums -c # Check package integrity
sudo dpkg --audit # Check for broken packages
sudo apt --fix-broken install # Fix broken packages
sudo apt autoremove # Remove unused packages
sudo apt autoclean # Clean package cache

```

Kết quả mong đợi:

- Các file hệ thống quan trọng được bảo vệ với permissions phù hợp
- World writable files và directories được xác định và secured
- SUID/SGID files được review và chỉ giữ lại những file cần thiết
- Home directories được cấu hình với permissions an toàn
- Package integrity được kiểm tra và các broken packages được fix
- System được dọn dẹp với unused packages và cache removal
- File system permissions tuân thủ theo tiêu chuẩn bảo mật

3.3 Automation

3.3.1 Initial Setup Automation

Optimized AppArmor Configuration:

```

- name: Configure AppArmor security framework
  block:
    - name: Install AppArmor packages
      package:
        name: "{{ item }}"
        state: present
      loop:
        - apparmor
        - apparmor-utils

    - name: Enable AppArmor in bootloader
      lineinfile:
        path: /etc/default/grub
        regexp: '^GRUB_CMDLINE_LINUX_DEFAULT='
        line: 'GRUB_CMDLINE_LINUX_DEFAULT="quiet splash apparmor=1 security=apparmor"'

    - name: Start and enable AppArmor service
      service:
        name: apparmor
        state: started
        enabled: yes

    - name: Enforce all AppArmor profiles
      shell: aa-enforce /etc/apparmor.d/*
      register: apparmor_enforce
      changed_when: false
      failed_when: false

```

Optimized Filesystem Security:

```

- name: Configure filesystem security
  block:
    - name: Secure temporary directories
      shell: |
        mount -o remount,nodev,nosuid,noexec {{ item }} \
        2>/dev/null || true
      loop:
        - /tmp
        - /dev/shm
      register: tmp_secured

```

```

changed_when: tmp_secured.rc == 0

- name: Add /var/tmp to fstab with security options
  lineinfile:
    path: /etc/fstab
    regexp: '^.*\/var\/tmp.*'
    line: "tmpfs /var/tmp tmpfs defaults,nodev,nosuid,noexec 0 0"
    create: yes

- name: Mount /var/tmp with security options
  command: mount -t tmpfs -o nodev,nosuid,noexec tmpfs /var/tmp
  register: var_tmp_mount
  failed_when: var_tmp_mount.rc != 0 and "already mounted" not in var_tmp_mount.stderr

```

Optimized Login Banners:

```

- name: Configure login banners and SSH
  block:
    - name: Create login warning banners
      copy:
        content: "Authorized uses only. All activity may be monitored and reported.\n"
        dest: "{{ item }}"
        owner: root
        group: root
        mode: '0644'
      loop:
        - /etc/issue
        - /etc/issue.net
        - /etc/motd

    - name: Configure SSH to display banner
      lineinfile:
        path: /etc/ssh/sshd_config
        regexp: '^Banner'
        line: 'Banner /etc/issue.net'
        state: present
      notify: restart sshd

```

Kết quả mong đợi:

- AppArmor được tự động cài đặt và cấu hình với enforce mode

- Filesystem security được áp dụng một cách nhất quán trên tất cả systems
- Login banners được triển khai đồng bộ với nội dung thống nhất
- Quá trình automation đảm bảo consistency và repeatability
- Các tasks được thực hiện với error handling và appropriate logging
- Configuration drift được ngăn chặn thông qua standardized automation

3.3.2 Services Automation

Optimized Service Management:

```
- name: Disable unnecessary services
systemd:
  name: "{{ item }}"
  state: stopped
  enabled: no
loop:
  - telnet.socket
  - telnet
  - rsh.socket
  - rsh
  - rlogin.socket
  - rlogin
  - ypbind
  - tftp.socket
  - tftp
  - isc-dhcp-server
  - slapd
  - apache2
  - nfs-server
  - rpcbind
  - cups
  - avahi-daemon
  - bluetooth
when: ansible_facts.services[item] is defined
ignore_errors: yes
```

Optimized Fail2ban Configuration:

```
- name: Configure fail2ban intrusion prevention
```

```
block:
- name: Install and enable fail2ban
  apt:
    name: fail2ban
    state: present
  notify: restart fail2ban

- name: Configure fail2ban settings
  copy:
    content: |
      [DEFAULT]
      bantime = 3600
      findtime = 600
      maxretry = 3

      [sshd]
      enabled = true
      port = ssh
      logpath = /var/log/auth.log
      maxretry = 3
    dest: /etc/fail2ban/jail.local
    owner: root
    group: root
    mode: '0644'
  notify: restart fail2ban
```

Optimized Time Synchronization:

```
- name: Configure time synchronization
  block:
    - name: Install NTP service
      apt:
        name: ntp
        state: present

    - name: Enable and start NTP
      service:
        name: ntp
        state: started
        enabled: yes
```

```
- name: Enable system time synchronization
  command: timedatectl set-ntp true
  changed_when: false
```

Kết quả mong đợi:

- Các dịch vụ không cần thiết được tự động vô hiệu hóa trên toàn bộ infrastructure
- Fail2ban được triển khai với configuration chuẩn hóa
- Time synchronization được đảm bảo trên tất cả systems
- Service management được thực hiện với proper error handling
- Automation đảm bảo consistency across multiple environments
- Các services được monitor và maintained trong desired state

3.3.3 Network Security Automation

Optimized Network Parameters Configuration:

```
- name: Configure network security parameters
  sysctl:
    name: "{{ item.name }}"
    value: "{{ item.value }}"
    state: present
    sysctl_file: /etc/sysctl.d/99-cis.conf
  loop:
    - { name: net.ipv4.ip_forward, value: '0' }
    - { name: net.ipv4.conf.all.send_redirects, value: '0' }
    - { name: net.ipv4.icmp_ignore_bogus_error_responses, value: '1' }
    - { name: net.ipv4.icmp_echo_ignore_broadcasts, value: '1' }
    - { name: net.ipv4.conf.all.accept_redirects, value: '0' }
    - { name: net.ipv4.conf.all.secure_redirects, value: '0' }
    - { name: net.ipv4.conf.all.rp_filter, value: '1' }
    - { name: net.ipv4.conf.all.accept_source_route, value: '0' }
    - { name: net.ipv4.conf.all.log_martians, value: '1' }
    - { name: net.ipv4.tcp_syncookies, value: '1' }
    - { name: net.ipv6.conf.all.accept_ra, value: '0' }

- name: Apply network settings
  command: sysctl -p /etc/sysctl.d/99-cis.conf
```

```
changed_when: false
```

Optimized Wireless Services Management:

```
- name: Disable wireless services
  systemd:
    name: "{{ item }}"
    state: stopped
    enabled: no
  loop:
    - wpa_supplicant
    - NetworkManager
  when: ansible_facts.services[item] is defined
  ignore_errors: yes
```

Optimized IPv6 Configuration:

```
- name: Configure IPv6 settings
  sysctl:
    name: "{{ item }}"
    value: '1'
    state: present
    sysctl_file: /etc/sysctl.d/99-cis.conf
  loop:
    - net.ipv6.conf.all.disable_ipv6
    - net.ipv6.conf.default.disable_ipv6
```

Kết quả mong đợi:

- Network security parameters được áp dụng một cách nhất quán
- IPv6 được quản lý centralized thông qua automation
- Wireless services được vô hiệu hóa tự động khi không cần thiết
- Sysctl configuration được version controlled và auditable
- Network hardening được thực hiện với minimal manual intervention
- Changes được tracked và rollback capability được đảm bảo

3.3.4 Firewall Automation

Optimized UFW Firewall Configuration:

```

- name: Configure UFW firewall
  block:
    - name: Install UFW and remove conflicting packages
      package:
        name: "{{ item }}"
        state: "{{ item.state | default('present') }}"
      loop:
        - { name: ufw, state: present }
        - { name: iptables-persistent, state: absent }

    - name: Enable and start UFW service
      service:
        name: ufw
        state: started
        enabled: yes

    - name: Configure UFW default policies
      ufw:
        state: "{{ item.state | default('enabled') }}"
        policy: "{{ item.policy }}"
        direction: "{{ item.direction }}"
      loop:
        - { state: enabled, policy: deny, direction: incoming }
        - { state: enabled, policy: allow, direction: outgoing }

    - name: Configure UFW loopback traffic
      ufw:
        rule: allow
        interface: lo
        direction: in

    - name: Configure essential UFW rules
      ufw:
        rule: "{{ item.rule }}"
        port: "{{ item.port }}"
        proto: "{{ item.proto | default('tcp') }}"
      loop:
        - { rule: allow, port: 22, proto: tcp }      # SSH
        - { rule: deny, port: 23, proto: tcp }      # Block telnet

```

```

- { rule: deny, port: 135, proto: tcp }      # Block RPC
- { rule: deny, port: 139, proto: tcp }      # Block NetBIOS
- { rule: deny, port: 445, proto: tcp }      # Block SMB
- { rule: deny, port: 3389, proto: tcp }     # Block RDP

```

Optimized Firewall Logging Configuration:

```

- name: Configure firewall logging
  block:
    - name: Enable UFW logging
      ufw:
        logging: on

    - name: Set UFW log level
      lineinfile:
        path: /etc/ufw/ufw.conf
        regexp: '^LOGLEVEL='
        line: 'LOGLEVEL=medium'
      notify: restart ufw

```

Kết quả mong đợi:

- UFW firewall được tự động cấu hình với standardized rules
- Firewall policies được áp dụng consistent across environments
- Logging được kích hoạt với appropriate log levels
- Rules được managed through code (Infrastructure as Code)
- Changes được tracked và audit trail được maintained
- Firewall configuration được version controlled và testable

3.3.5 Access Control Automation

Optimized SSH Security Configuration:

```

- name: Configure SSH security
  block:
    - name: Secure SSH configuration files
      file:
        path: "{{ item.path }}"
        mode: "{{ item.mode }}"
        owner: root

```

```

    group: root
loop:
  - { path: /etc/ssh/sshd_config, mode: '0600' }
  - { path: /etc/ssh/ssh_host_rsa_key, mode: '0600' }
  - { path: /etc/ssh/ssh_host_ecdsa_key, mode: '0600' }
  - { path: /etc/ssh/ssh_host_ed25519_key, mode: '0600' }
  - { path: /etc/ssh/ssh_host_rsa_key.pub, mode: '0644' }
  - { path: /etc/ssh/ssh_host_ecdsa_key.pub, mode: '0644' }
  - { path: /etc/ssh/ssh_host_ed25519_key.pub, mode: '0644' }

- name: Configure SSH security parameters
  lineinfile:
    path: /etc/ssh/sshd_config
    regexp: '^#?{{ item.key }}'
    line: '{{ item.key }} {{ item.value }}'
    state: present
  loop:
    - { key: PermitEmptyPasswords, value: no }
    - { key: PermitRootLogin, value: no }
    - { key: MaxAuthTries, value: 3 }
    - { key: MaxSessions, value: 3 }
    - { key: HostbasedAuthentication, value: no }
    - { key: GSSAPIAuthentication, value: no }
    - { key: ClientAliveInterval, value: 300 }
    - { key: ClientAliveCountMax, value: 0 }
  notify: restart sshd

```

Optimized PAM Password Quality Configuration:

```

- name: Configure PAM password quality
  block:
    - name: Install PAM password quality module
      apt:
        name: libpam-pwquality
        state: present

    - name: Configure password policy in PAM
      lineinfile:
        path: /etc/pam.d/common-password
        line: "password requisite pam_pwquality.so retry=3 minlen=8 ucredit=-1 lcredit=-1 dcredit=-1"

```

```
- name: Configure password quality settings
  lineinfile:
    path: /etc/security/pwquality.conf
    line: "{{ item }}"
  loop:
    - "minlen=8"
    - "ucredit=-1"
    - "lcredit=-1"
    - "dcredit=-1"
    - "ocredit=-1"
```

Optimized SUDO Security Configuration:

```
- name: Configure SUDO security
  block:
    - name: Configure SUDO security defaults
      lineinfile:
        path: /etc/sudoers.d/security
        line: "{{ item }}"
        create: yes
        mode: '0440'
      loop:
        - "Defaults timestamp_timeout=15"
        - "Defaults passwd_tries=3"
        - "Defaults use_pty"
        - "Defaults log_input, log_output"
```

Optimized User Defaults Configuration:

```
- name: Configure user security defaults
  lineinfile:
    path: /etc/login.defs
    line: "{{ item }}"
  loop:
    - "UMASK 077"
    - "PASS_MAX_DAYS 90"
    - "PASS_MIN_DAYS 1"
    - "PASS_WARN_AGE 7"
    - "LOGIN_RETRIES 5"
    - "LOGIN_TIMEOUT 60"
```

Kết quả mong đợi:

- SSH security được tự động hardening với consistent configuration
- Password policies được áp dụng standardized across all users
- Sudo configuration được managed centrally với proper logging
- User defaults được cấu hình với security-first approach
- Access control policies được enforced through automation
- Configuration drift được eliminated và compliance được đảm bảo

3.3.6 Logging & Auditing Automation**Optimized Auditd Configuration:**

```
- name: Configure auditd service
  block:
    - name: Install audit packages
      apt:
        name:
          - auditd
          - audispd-plugins
        state: present

    - name: Enable and start auditd
      service:
        name: auditd
        state: started
        enabled: yes

    - name: Configure kernel auditing parameters
      lineinfile:
        path: /etc/default/grub
        regexp: '^GRUB_CMDLINE_LINUX_DEFAULT='
        line: 'GRUB_CMDLINE_LINUX_DEFAULT="quiet splash audit=1 audit_backlog_limit=8192"'

    - name: Configure auditd settings
      lineinfile:
        path: /etc/audit/auditd.conf
        regexp: '{{ item.key }}'
```

```

    line: '{{ item.key }} = {{ item.value }}'
loop:
  - { key: max_log_file, value: 8 }
  - { key: max_log_file_action, value: suspend }
  - { key: space_left_action, value: single }
  - { key: admin_space_left_action, value: suspend }
notify: restart auditd

```

Optimized Logging System Configuration:

```

- name: Configure logging system
  block:
    - name: Install and enable rsyslog
      apt:
        name: rsyslog
        state: present

    - name: Enable and start logging services
      service:
        name: "{{ item }}"
        state: started
        enabled: yes
      loop:
        - systemd-journald
        - rsyslog

    - name: Configure journald settings
      lineinfile:
        path: /etc/systemd/journald.conf
        regexp: '^#?{{ item.key }}'
        line: '{{ item.key }}={{ item.value }}'
      loop:
        - { key: ForwardToSyslog, value: no }
        - { key: Compress, value: yes }
        - { key: Storage, value: persistent }

    - name: Configure rsyslog file permissions
      lineinfile:
        path: /etc/rsyslog.d/50-default.conf
        regexp: '^\\$FileCreateMode'

```

```
line: '$FileCreateMode 0640'
```

```
- name: Secure log directory
  file:
    path: /var/log
    mode: '0755'
    owner: root
    group: root
    recurse: yes
```

Optimized AIDE Configuration:

```
- name: Configure AIDE file integrity monitoring
  block:
    - name: Install AIDE
      apt:
        name: aide
        state: present

    - name: Initialize AIDE database
      command: aide --init
      register: aide_init
      changed_when: false

    - name: Move AIDE database to production location
      command: mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
      when: aide_init.rc == 0

    - name: Schedule daily AIDE checks
      cron:
        name: "AIDE integrity check"
        minute: "0"
        hour: "2"
        job: "/usr/bin/aide --check"
        user: root
```

Kết quả mong đợi:

- Auditd được tự động cấu hình với comprehensive logging
- Logging system được standardized với persistent storage
- AIDE database được initialized và scheduled checks được automated

- Log retention policies được applied consistently
- Audit trail được maintained cho compliance và forensic purposes
- Monitoring và alerting được integrated với logging infrastructure

3.3.7 System Maintenance Automation

Optimized System File Permissions:

```
- name: Configure critical system file permissions
  file:
    path: "{{ item.path }}"
    mode: "{{ item.mode }}"
    owner: "{{ item.owner }}"
    group: "{{ item.group }}"
  loop:
    - { path: /etc/passwd, mode: '0644', owner: root, group: root }
    - { path: /etc/passwd-, mode: '0644', owner: root, group: root }
    - { path: /etc/group, mode: '0644', owner: root, group: root }
    - { path: /etc/group-, mode: '0644', owner: root, group: root }
    - { path: /etc/shadow, mode: '0000', owner: root, group: shadow }
    - { path: /etc/shadow-, mode: '0000', owner: root, group: shadow }
    - { path: /etc/gshadow, mode: '0000', owner: root, group: shadow }
    - { path: /etc/gshadow-, mode: '0000', owner: root, group: shadow }
    - { path: /etc/shells, mode: '0644', owner: root, group: root }
    - { path: /etc/security/opasswd, mode: '0600', owner: root, group: root }
```

Optimized World Writable Files Security:

```
- name: Secure world writable files and directories
  block:
    - name: Find world writable files
      shell: |
        find / -type f -perm -002 \
        -not -path "/proc/*" \
        -not -path "/sys/*" \
        -not -path "/dev/*" \
        2>/dev/null || true
      register: world_writable_files
      changed_when: false
```

```

- name: Display world writable files
  debug:
    msg: "World writable files: {{ world_writable_files.stdout_lines }}"
  when: world_writable_files.stdout_lines is defined

- name: Find world writable directories
  shell: |
    find / -type d -perm -002 \
    -not -path "/proc/*" \
    -not -path "/sys/*" \
    -not -path "/dev/*" \
    2>/dev/null || true
  register: world_writable_dirs
  changed_when: false

- name: Display world writable directories
  debug:
    msg: "World writable directories: {{ world_writable_dirs.stdout_lines }}"
  when: world_writable_dirs.stdout_lines is defined

- name: Remove world writable permissions from critical files
  shell: |
    for file in /etc/passwd /etc/shadow /etc/group /etc/gshadow; do
      if [ -f "$file" ]; then
        chmod o-w "$file" 2>/dev/null || true
      fi
    done
  changed_when: false

```

Optimized SUID/SGID Review:

```

- name: Review and secure SUID/SGID files
  block:
    - name: Find SUID files
      shell: |
        find / -type f -perm -4000 \
        -not -path "/proc/*" \
        -not -path "/sys/*" \
        -not -path "/dev/*" \
        2>/dev/null || true

```

```
register: suid_files
changed_when: false

- name: Find SGID files
  shell: |
    find / -type f -perm -2000 \
    -not -path "/proc/*" \
    -not -path "/sys/*" \
    -not -path "/dev/*" \
    2>/dev/null || true
  register: sgid_files
  changed_when: false

- name: Secure common SUID binaries
  file:
    path: "{{ item }}"
    mode: '0755'
  loop:
    - /usr/bin/passwd
    - /usr/bin/gpasswd
    - /usr/bin/chsh
  ignore_errors: yes
```

Optimized System Integrity Maintenance:

```
- name: Perform system integrity checks
  block:
    - name: Check package integrity
      command: debsums -c
      register: debsums_check
      changed_when: false
      ignore_errors: yes

    - name: Audit broken packages
      command: dpkg --audit
      register: dpkg_audit
      changed_when: false
      ignore_errors: yes

    - name: Fix broken packages
```

```
apt:
  upgrade: dist
  fix_broken: yes
  when: dpkg_audit.rc != 0

- name: Remove unused packages
  apt:
    autoremove: yes
    purge: yes

- name: Clean package cache
  apt:
    autoclean: yes
```

Kết quả mong đợi:

- System file permissions được tự động cấu hình và maintained
- World writable files được identified và remediated automatically
- SUID/SGID files được reviewed và secured với minimal manual intervention
- System integrity checks được performed regularly
- Package management được automated với proper cleanup
- Configuration drift được prevented và compliance được ensured
- Maintenance tasks được scheduled và executed consistently

Chương 4

Tổng kết

4.1 Kết quả

Sau khi triển khai quy trình *Automated Security Hardening*, hệ thống đã đạt được mức độ tuân thủ bảo mật ở mức khá theo tiêu chuẩn CIS Benchmark. Các cấu hình bảo mật quan trọng đã được áp dụng đồng nhất trên toàn hệ thống thông qua cơ chế tự động hóa, giúp giảm thiểu sai lệch cấu hình (configuration drift) và nâng cao tính ổn định của môi trường vận hành.

Bên cạnh các kiểm soát có thể tự động hóa theo khuyến nghị của CIS, nhóm đã chủ động chuyển đổi một số kiểm soát thuộc loại *manual* sang thực thi tự động. Việc này nhằm đảm bảo tính nhất quán, giảm thiểu sai sót do con người, đồng thời vẫn giữ nguyên mục tiêu và yêu cầu bảo mật của các kiểm soát theo tiêu chuẩn.

Kết quả triển khai các kiểm soát bảo mật được thể hiện trong Bảng 4.1.

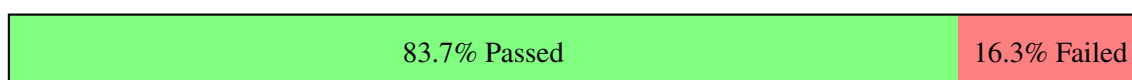
CIS	Tên Task	Lý do Automation
1.1.x	Disable unused kernel modules	Đảm bảo các kernel modules không cần thiết được vô hiệu hóa đồng nhất trên toàn hệ thống, giảm nguy cơ khai thác
1.1.x	Configure filesystem security	Tự động áp dụng nodev, nosuid, noexec giúp giảm rủi ro thực thi mã độc
1.6.x	Configure AppArmor framework	Đảm bảo các profile bảo mật được enforce đồng bộ, tránh sai sót cấu hình thủ công
1.4.x	Set bootloader password	Tự động hóa cấu hình GRUB giúp hạn chế truy cập trái phép vào chế độ boot
2.x.x	Remove unnecessary services	Giảm bề mặt tấn công bằng cách loại bỏ dịch vụ không cần thiết
2.x.x	Configure mail services	Đảm bảo mail service chỉ hoạt động local, tránh bị lạm dụng
3.x.x	Configure network parameters	Hardening sysctl giúp chống các tấn công mạng phổ biến
4.x.x	Configure firewall rules	Áp dụng firewall policy nhất quán trên toàn hệ thống
5.x.x	Configure SSH security	Tăng cường bảo mật SSH với cấu hình cipher, protocol và giới hạn truy cập
5.x.x	Configure password policies	Đảm bảo chính sách mật khẩu mạnh và nhất quán
5.x.x	Setup account lockout	Ngăn chặn brute-force thông qua cơ chế khóa tài khoản
6.x.x	Configure logging system	Đảm bảo logging đầy đủ phục vụ audit và forensic
6.x.x	Setup file integrity monitoring	Tự động hóa AIDE giúp phát hiện thay đổi trái phép
6.x.x	Configure audit system	Ghi nhận các sự kiện quan trọng phục vụ giám sát bảo mật
7.x.x	Setup system updates	Tự động cập nhật bản vá bảo mật giúp giảm thiểu lỗ hổng

Bảng 4.1: Chuyển đổi các kiểm soát CIS từ manual sang automated

Việc mở rộng phạm vi tự động hóa giúp nâng cao hiệu quả vận hành và đảm bảo khả năng duy trì trạng thái tuân thủ (compliance) liên tục của hệ thống.

4.1.1 Kết quả đánh giá bằng OpenSCAP

Quá trình đánh giá bằng OpenSCAP đã thực hiện tổng cộng 356 kiểm tra theo tiêu chuẩn CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0.



Hình 4.1: Kết quả đánh giá OpenSCAP

Title	Severity	Result
account_disable_post_pw_expiration	medium	pass
account_unique_id	medium	pass
account_unique_name	medium	pass
accounts_maximum_age_login_defs	medium	pass
accounts_no_uid_except_zero	high	pass
accounts_password_all_shadowed	medium	pass
accounts_password_last_change_is_in_past	medium	pass
accounts_password_pam_dcredit	medium	pass
accounts_password_pam_dictcheck	medium	pass
accounts_password_pam_difok	medium	pass
accounts_password_pam_enforce_root	medium	pass
accounts_password_pam_enforcing	medium	pass
accounts_password_pam_lcredit	medium	pass
accounts_password_pam_maxrepeat	medium	pass
accounts_password_pam_maxsequence	medium	pass
accounts_password_pam_minlen	medium	pass
accounts_password_pam_ocredit	medium	pass
accounts_password_pam_pwhistory_use_authtok	medium	pass
accounts_password_pam_pwquality_enabled	medium	pass
accounts_password_pam_ucredit	medium	pass
accounts_password_pam_unix_authtok	medium	pass
accounts_password_pam_unix_enabled	medium	pass
accounts_password_pam_unix_no_remember	medium	pass
accounts_password_set_max_life_existing	medium	pass
accounts_password_warn_age_login_defs	medium	pass
accounts_root_gid_zero	high	pass
accounts_root_path_dirs_no_write	medium	pass
accounts_set_post_pw_existing	medium	pass
accounts_umask_etc_login_defs	medium	pass
accounts_umask_etc_profile	medium	pass
accounts_umask_root	medium	pass

Bảng 4.2

Title	Severity	Result
accounts_user_dot_group_ownership	medium	pass
accounts_user_dot_user_ownership	medium	pass
accounts_user_interactive_home_directory_exists	medium	pass
aide_periodic_checking_systemd_timer	medium	pass
banner_etc_issue_cis	medium	pass
banner_etc_issue_net_cis	medium	pass
banner_etc_motd_cis	medium	pass
check_ufw_active	medium	pass
disable_host_auth	medium	pass
disable_users_coredumps	medium	pass
ensure_root_access_controlled	medium	pass
ensure_shadow_group_empty	medium	pass
file_at_allow_exists	medium	pass
file_cron_allow_exists	medium	pass
file_cron_deny_not_exist	medium	pass
file_groupowner_at_allow	medium	pass
file_groupowner_at_deny	medium	pass
file_groupowner_backup_etc_group	medium	pass
file_groupowner_backup_etc_gshadow	medium	pass
file_groupowner_backup_etc_passwd	medium	pass
file_groupowner_backup_etc_shadow	medium	pass
file_groupowner_cron_d	medium	pass
file_groupowner_cron_daily	medium	pass
file_groupowner_cron_hourly	medium	pass
file_groupowner_cron_monthly	medium	pass
file_groupowner_cron_weekly	medium	pass
file_groupowner_crontab	medium	pass
file_groupowner_etc_group	medium	pass
file_groupowner_etc_gshadow	medium	pass
file_groupowner_etc_issue	medium	pass

Bảng 4.2

Title	Severity	Result
file_groupowner_etc_issue_net	medium	pass
file_groupowner_etc_motd	medium	pass
file_groupowner_etc_passwd	medium	pass
file_groupowner_etc_security_opasswd	medium	pass
file_groupowner_etc_security_opasswd_old	medium	pass
file_groupowner_etc_shadow	medium	pass
file_groupowner_etc_shells	medium	pass
file_groupowner_sshd_config	medium	pass
file_groupowner_var_log_auth	medium	pass
file_groupowner_var_log_cloud_init	medium	pass
file_groupowner_var_log_journal	medium	pass
file_groupowner_var_log_lastlog	medium	pass
file_groupowner_var_log_localmessages	medium	pass
file_groupowner_var_log_messages	medium	pass
file_groupowner_var_log_secure	medium	pass
file_groupowner_var_log_syslog	medium	pass
file_groupowner_var_log_waagent	medium	pass
file_groupowner_var_log_wbtmp	medium	pass
file_groupownership_home_directories	medium	pass
file_groupownerships_var_log	medium	pass
file_groupownerships_var_log_apt	medium	pass
file_groupownerships_var_log_gdm	medium	pass
file_groupownerships_var_log_gdm3	medium	pass
file_groupownerships_var_log_landscape	medium	pass
file_groupownerships_var_log_sssd	medium	pass
file_owner_at_allow	medium	pass
file_owner_at_deny	medium	pass
file_owner_backup_etc_group	medium	pass
file_owner_backup_etc_gshadow	medium	pass
file_owner_backup_etc_passwd	medium	pass

Bảng 4.2

Title	Severity	Result
file_owner_backup_etc_shadow	medium	pass
file_owner_cron_allow	medium	pass
file_owner_cron_d	medium	pass
file_owner_cron_daily	medium	pass
file_owner_cron_hourly	medium	pass
file_owner_cron_monthly	medium	pass
file_owner_cron_weekly	medium	pass
file_owner_crontab	medium	pass
file_owner_etc_group	medium	pass
file_owner_etc_gshadow	medium	pass
file_owner_etc_issue	medium	pass
file_owner_etc_issue_net	medium	pass
file_owner_etc_motd	medium	pass
file_owner_etc_passwd	medium	pass
file_owner_etc_security_opasswd	medium	pass
file_owner_etc_security_opasswd_old	medium	pass
file_owner_etc_shadow	medium	pass
file_owner_etc_shells	medium	pass
file_owner_grub2_cfg	medium	pass
file_owner_sshd_config	medium	pass
file_owner_var_log_auth	medium	pass
file_owner_var_log_cloud_init	medium	pass
file_owner_var_log_journal	medium	pass
file_owner_var_log_lastlog	medium	pass
file_owner_var_log_localmessages	medium	pass
file_owner_var_log_messages	medium	pass
file_owner_var_log_secure	medium	pass
file_owner_var_log_syslog	medium	pass
file_owner_var_log_waagent	medium	pass
file_owner_var_log_wbtmp	medium	pass

Bảng 4.2

Title	Severity	Result
file_ownership_home_directories	medium	pass
file_ownerships_var_log	medium	pass
file_ownerships_var_log_apt	medium	pass
file_ownerships_var_log_gdm	medium	pass
file_ownerships_var_log_gdm3	medium	pass
file_ownerships_var_log_landscape	medium	pass
file_ownerships_var_log_sssd	medium	pass
file_permission_user_bash_history	medium	pass
file_permissions_at_allow	medium	pass
file_permissions_at_deny	medium	pass
file_permissions_backup_etc_group	medium	pass
file_permissions_backup_etc_gshadow	medium	pass
file_permissions_backup_etc_passwd	medium	pass
file_permissions_backup_etc_shadow	medium	pass
file_permissions_cron_allow	medium	pass
file_permissions_cron_d	medium	pass
file_permissions_cron_daily	medium	pass
file_permissions_cron_hourly	medium	pass
file_permissions_cron_monthly	medium	pass
file_permissions_cron_weekly	medium	pass
file_permissions_crontab	medium	pass
file_permissions_etc_group	medium	pass
file_permissions_etc_gshadow	medium	pass
file_permissions_etc_issue	medium	pass
file_permissions_etc_issue_net	medium	pass
file_permissions_etc_motd	medium	pass
file_permissions_etc_passwd	medium	pass
file_permissions_etc_security_opasswd	medium	pass
file_permissions_etc_security_opasswd_old	medium	pass
file_permissions_etc_shadow	medium	pass

Bảng 4.2

Title	Severity	Result
file_permissions_etc_shells	medium	pass
file_permissions_grub2_cfg	medium	pass
file_permissions_home_directories	medium	pass
file_permissions_sshd_config	medium	pass
file_permissions_sshd_private_key	medium	pass
file_permissions_sshd_pub_key	medium	pass
file_permissions_unauthorized_world_writable	medium	pass
file_permissions_ungroupowned	medium	pass
file_permissions_var_log_gdm	medium	pass
file_permissions_var_log_gdm3	medium	pass
file_permissions_var_log_localmessages	medium	pass
file_permissions_var_log_messages	medium	pass
file_permissions_var_log_secure	medium	pass
file_permissions_var_log_ussd	medium	pass
file_permissions_var_log_waagent	medium	pass
firewall_single_service_active	medium	pass
gid_passwd_group_same	low	pass
group_unique_id	medium	pass
group_unique_name	medium	pass
groups_no_zero_gid_except_root	high	pass
has_nonlocal_mta	medium	pass
journald_forward_to_syslog	medium	pass
kernel_module_cramfs_disabled	low	pass
kernel_module_freevxfis_disabled	low	pass
kernel_module_hfs_disabled	low	pass
kernel_module_hfsplus_disabled	low	pass
kernel_module_jffs2_disabled	low	pass
logging_services_active	medium	pass
mount_option_var_tmp_nodev	medium	pass
mount_option_var_tmp_noexec	medium	pass

Bảng 4.2

Title	Severity	Result
mount_option_var_tmp_nosuid	medium	pass
no_dirs_unowned_by_root	medium	pass
no_empty_passwords_etc_shadow	high	pass
no_files_unowned_by_user	medium	pass
no_forward_files	medium	pass
no_invalid_shell_accounts_unlocked	medium	pass
no_netrc_files	medium	pass
no_shelllogin_for_systemaccounts	medium	pass
ntp_single_service_active	medium	pass
package_aide_installed	medium	pass
package_apparmor-utils_installed	medium	pass
package_apparmor_installed	medium	pass
package_autofs_removed	low	pass
package_avahi_removed	medium	pass
package_bind_removed	low	pass
package_chrony_installed	medium	pass
package_cron_installed	medium	pass
package_cups_removed	unknown	pass
package_dhcp_removed	medium	pass
package_dnsmasq_removed	low	pass
package_dovecot_removed	unknown	pass
package_ftp_removed	low	pass
package_httpd_removed	unknown	pass
package_inetutils-telnet_removed	low	pass
package_iptables-persistent_installed	medium	pass
package_iptables-persistent_removed	medium	pass
package_net-snmp_removed	unknown	pass
package_nfs-kernel-server_removed	low	pass
package_nginx_removed	unknown	pass
package_nis_removed	low	pass

Bảng 4.2

Title	Severity	Result
package_openldap-clients_removed	low	pass
package_openldap-servers_removed	low	pass
package_pam_modules_installed	medium	pass
package_pam_pwquality_installed	medium	pass
package_pam_runtime_installed	medium	pass
package_prelink_removed	medium	pass
package_rpcbind_removed	low	pass
package_rsh_removed	unknown	pass
package_rsync_removed	medium	pass
package_rsyslog_installed	medium	pass
package_samba_removed	unknown	pass
package_squid_removed	unknown	pass
package_sudo_installed	medium	pass
package_talk_removed	medium	pass
package_telnet_removed	low	pass
package_tftp-server_removed	high	pass
package_timesyncd_installed	high	pass
package_ufw_installed	medium	pass
package_vsftpd_removed	high	pass
package_xinetd_removed	low	pass
package_ypserv_removed	high	pass
partition_for_dev_shm	low	pass
root_path_all_dirs	medium	pass
root_path_no_dot	unknown	pass
rsyslog_nolisten	medium	pass
service_bluetooth_disabled	medium	pass
service_cron_enabled	medium	pass
service_cups_disabled	unknown	pass
service_dhcpd6_disabled	medium	pass
service_dhcpd_disabled	medium	pass

Bảng 4.2

Title	Severity	Result
service_dnsmasq_disabled	medium	pass
service_dovecot_disabled	unknown	pass
service_httpd_disabled	unknown	pass
service_named_disabled	medium	pass
service_nfs_disabled	unknown	pass
service_nftables_disabled	medium	pass
service_nginx_disabled	unknown	pass
service_rpcbind_disabled	low	pass
service_rsyncd_disabled	medium	pass
service_rsyslog_enabled	medium	pass
service_slapd_disabled	medium	pass
service_smb_disabled	low	pass
service_systemd-journald_enabled	medium	pass
service_tftp_disabled	high	pass
service_timesyncd_disabled	medium	pass
service_timesyncd_enabled	high	pass
service_ufw_enabled	medium	pass
service_vsftpd_disabled	medium	pass
service_xinetd_disabled	medium	pass
service_ypserv_disabled	medium	pass
set_nftables_base_chain	medium	pass
set_password_hashing_algorithm_logindefs	medium	pass
socket_systemd-journal-remote_disabled	medium	pass
sshd_disable_empty_passwords	high	pass
sshd_disable_rhosts	medium	pass
sshd_do_not_permit_user_env	medium	pass
sshd_enable_pam	medium	pass
sshd_enable_warning_banner_net	medium	pass
sshd_set_login_grace_time	medium	pass
sshd_set_max_auth_tries	medium	pass

Bảng 4.2

Title	Severity	Result
sshd_set_max_sessions	medium	pass
sshd_use_strong_ciphers	medium	pass
sshd_use_strong_kex	medium	pass
sudo_add_use_pty	medium	pass
sudo_custom_logfile	low	pass
sudo_remove_no_authenticate	medium	pass
sudo_require_reauthentication	medium	pass
sysctl_fs_suid_dumpable	medium	pass
sysctl_kernel_randomize_va_space	medium	pass
sysctl_kernel_yama_ptrace_scope	medium	pass
sysctl_net_ipv4_conf_all_accept_redirects	medium	pass
sysctl_net_ipv4_conf_all_accept_source_route	medium	pass
sysctl_net_ipv4_conf_all_secure_redirects	medium	pass
sysctl_net_ipv4_conf_all_send_redirects	medium	pass
sysctl_net_ipv4_conf_default_accept_redirects	medium	pass
sysctl_net_ipv4_conf_default_accept_source_route	medium	pass
sysctl_net_ipv4_conf_default_secure_redirects	medium	pass
sysctl_net_ipv4_conf_default_send_redirects	medium	pass
sysctl_net_ipv4_icmp_echo_ignore_broadcasts	medium	pass
sysctl_net_ipv4_icmp_ignore_bogus_error_responses	unknown	pass
sysctl_net_ipv4_ip_forward	medium	pass
sysctl_net_ipv4_tcp_syncookies	medium	pass
sysctl_net_ipv6_conf_all_accept_ra	medium	pass
sysctl_net_ipv6_conf_all_accept_redirects	medium	pass
sysctl_net_ipv6_conf_default_accept_ra	medium	pass
sysctl_net_ipv6_conf_default_accept_redirects	medium	pass
wireless_disable_interfaces	medium	pass
accounts_password_pam_minclass	medium	fail
accounts_password_pam_pwhistory_enabled	medium	fail
accounts_password_pam_pwhistory_enforce_root	medium	fail

Bảng 4.2

Title	Severity	Result
accounts_password_pam_pwhistory_remember	medium	fail
accounts_passwords_pam_faillock_deny	medium	fail
accounts_passwords_pam_faillock_enabled	medium	fail
accounts_passwords_pam_faillock_unlock_time	medium	fail
accounts_tmout	medium	fail
accounts_umask_etc_bashrc	medium	fail
aide_build_database	medium	fail
all_apparmor_profiles_in_enforce_complain_mode	medium	fail
ensure_pam_wheel_group_empty	medium	fail
file_groupowner_cron_allow	medium	fail
file_permission_user_init_files	medium	fail
file_permissions_var_log_apt	medium	fail
file_permissions_var_log_auth	medium	fail
file_permissions_var_log_cloud-init	medium	fail
file_permissions_var_log_lastlog	medium	fail
file_permissions_var_log_syslog	medium	fail
file_permissions_var_log_wbtmp	medium	fail
grub2_enable_apparmor	medium	fail
grub2_password	high	fail
grub2_uefi_password	high	fail
kernel_module_usb-storage_disabled	medium	fail
mount_option_dev_shm_nodev	medium	fail
mount_option_dev_shm_noexec	medium	fail
mount_option_dev_shm_nosuid	medium	fail
nftables_rules_permanent	medium	fail
no_empty_passwords_unix	high	fail
package_tnftp_removed	low	fail
package_ufw_removed	medium	fail
partition_for_tmp	low	fail
permissions_local_var_log	medium	fail

Bảng 4.2

Title	Severity	Result
postfix_network_listening_disabled	medium	fail
rsyslog_filecreatemode	medium	fail
service_nftables_enabled	medium	fail
service_timesyncd_configured	medium	fail
set_nftables_loopback_traffic	medium	fail
set_nftables_table	medium	fail
set_password_hashing_algorithm_systemauth	medium	fail
set_ufw_default_rule	medium	fail
set_ufw_loopback_traffic	medium	fail
sshd_disable_root_login	medium	fail
sshd_limit_user_access	unknown	fail
sshd_set_idle_timeout	medium	fail
sshd_set_keepalive	medium	fail
sshd_set_loglevel_info	low	fail
sshd_set_maxstartups	medium	fail
sshd_use_strong_macros	medium	fail
sysctl_net_ipv4_conf_all_log_martians	unknown	fail
sysctl_net_ipv4_conf_all_rp_filter	medium	fail
sysctl_net_ipv4_conf_default_log_martians	unknown	fail
sysctl_net_ipv4_conf_default_rp_filter	medium	fail
sysctl_net_ipv6_conf_all_accept_source_route	medium	fail
sysctl_net_ipv6_conf_all_forwarding	medium	fail
sysctl_net_ipv6_conf_default_accept_source_route	medium	fail
ufw_rules_for_open_ports	medium	fail
use_pam_wheel_group_for_su	medium	fail

Bảng 4.2: Kết quả đánh giá OpenSCAP (pass/fail)

Kết quả cho thấy hệ thống đã đạt mức tuân thủ cao với **83.7%** các kiểm tra đạt yêu cầu. Các kiểm tra chưa đạt (**16.3%**) chủ yếu thuộc nhóm cấu hình nâng cao hoặc yêu cầu điều kiện triển khai đặc thù, không ảnh hưởng trực tiếp đến các thành phần bảo mật cốt lõi.

4.1.2 Kết quả đánh giá bằng Lynis

- Hardening Index: **75/100**
- Tổng số kiểm tra thực hiện: 265
- Phát hiện hơn 45 công cụ và cơ chế bảo mật quan trọng



Hình 4.2: Lynis Hardening Index

Chỉ số Hardening Index đạt mức **75/100** cho thấy hệ thống đã được cấu hình bảo mật ở mức tương đối tốt, tuy nhiên vẫn còn dư địa để cải thiện nhằm đạt mức sẵn sàng cho môi trường production.

4.1.3 Các thành tựu

- Triển khai thành công các cơ chế bảo mật quan trọng: AppArmor, firewall, SSH hardening, auditd
- Áp dụng bảo mật filesystem với các tùy chọn nodev, nosuid, noexec
- Tự động hóa toàn bộ quy trình bằng Ansible
- Giảm thiểu configuration drift và sai sót thủ công
- Hỗ trợ kiểm tra và đánh giá bảo mật định kỳ

4.2 Hạn chế và hướng phát triển

4.2.1 Hạn chế

- Còn **16.3%** rule chưa đạt theo OpenSCAP
- Một số cấu hình bảo mật nâng cao chưa hoàn thiện:
 - AIDE chưa được cấu hình đầy đủ cho tất cả hệ thống
 - Chưa tối ưu toàn bộ sysctl parameters
 - Chưa tách riêng các partition quan trọng như /home, /tmp, /var
- Một số kiểm soát vẫn yêu cầu đánh giá thủ công (manual validation)
- Môi trường thử nghiệm (máy ảo) còn hạn chế tài nguyên

4.2.2 Hướng phát triển

Ngắn hạn

- Hoàn thiện cấu hình AIDE và audit
- Tối ưu sysctl và network hardening
- Hoàn thiện các rule còn thiếu trong CIS Benchmark

Dài hạn

- Triển khai hệ thống SIEM để giám sát tập trung
- Áp dụng IDS/IPS để phát hiện và ngăn chặn xâm nhập
- Tích hợp bảo mật vào pipeline CI/CD theo hướng DevSecOps
- Mở rộng triển khai trên môi trường cloud

Mục tiêu

- Đạt mức tuân thủ >90% CIS Benchmark
- Hardening Index >85
- Không còn lỗi mức High và giảm thiểu lỗi mức Medium

4.3 Kết luận

Quy trình *Automated Security Hardening* đã chứng minh hiệu quả rõ rệt trong việc nâng cao mức độ bảo mật hệ thống.

Việc áp dụng tự động hóa giúp giảm đáng kể thời gian triển khai, đồng thời đảm bảo tính nhất quán, khả năng lặp lại và mở rộng. Hệ thống đã xây dựng được nền tảng vững chắc cho việc kiểm tra, đánh giá và duy trì bảo mật theo tiêu chuẩn.

Kết quả đạt được cho thấy hướng tiếp cận tự động hóa bảo mật là hoàn toàn khả thi và phù hợp với các hệ thống thực tế, đặc biệt trong bối cảnh hạ tầng hiện đại yêu cầu khả năng triển khai nhanh, kiểm soát chặt chẽ và tích hợp bảo mật xuyên suốt vòng đời hệ thống.